

Guía de Laboratorio · Sesión 5 · Investigación de incidente y monitoreo de backups · 92-EAN

Parte 1 · Triage del incidente en Wazuh (SIEM)

Taller Sesión 5 · Ciber-Recuperación (92-EAN) · Duración: 25 min Rol: eres el analista de guardia del SOC. Herramienta: **Wazuh** (por navegador).

A las 3 a. m. saltaron alertas. El actor **Locked3D** (el mismo de la S3) está dentro. Tu trabajo ahora **no** es recuperar todavía: es **entender qué pasó** — reconstruir la cadena de ataque (kill chain) y decidir a qué backups apuntó.

0. Entra al SOC

Tu docente te dará la **URL del dashboard** y tu **usuario/clave** (read-only):

```
https://<IP-del-SOC>      usuario: alumnoNN      clave: EanSOC2026-xxxx
```

Acepta el certificado autofirmado. Vas a **Threat Hunting** → **Events** (o *Discover*), índice **wazuh-alerts-***. Todo lo que investigas ya está ahí: no modificas nada, solo consultas — como un analista real con permisos de lectura.

1. Encuentra el incidente (5 min)

En la barra de búsqueda (DQL), filtra las alertas del actor:

```
rule.groups: locked3d
```

Deberías ver **10 alertas**. Ordena por tiempo ascendente. Responde en tu bitácora:

- ¿Cuántos **hosts** están afectados? (pista: agrupa por **data.win.system.computer**)
- ¿Cuál es el **paciente cero** (donde empezó) y cuál el **objetivo final**?
- ¿Qué **nivel** tienen las alertas más críticas (**rule.level**)?

2. Reconstruye la kill chain (10 min)

Cada alerta es un eslabón. Usando `rule.description`, `rule.mitre.id` y el `timestamp`, ordena la secuencia del ataque. Complétala en tu bitácora:

#	Hora	Qué pasó	Técnica MITRE
1	03:05	Documento señuelo abre...	T1204.002
2		PowerShell ofuscado (<code>-enc</code>)	T1059.001
3		Payload desde <code>%TEMP%</code>	
4		Borrado de shadow copies	T1490
5		<code>bcdedit</code> recuperación deshabilitada	
6		Limpieza de logs de eventos	T1070.001
7		Cifrado de archivos <code>.locked3d</code>	T1486
8		Nota de rescate	
9		Conexión a dominio <code>.onion</code>	T1071

Preguntas de analista: - ¿Por qué el atacante **borra shadow copies y deshabilita la recuperación ANTES** de cifrar? ¿Qué te dice eso sobre su objetivo? - ¿Por qué **limpia los logs**? ¿Qué intenta impedir (y qué te habría pasado si no tuvieras un SIEM que ya los recibió)?

3. Sigue el rastro hasta los BACKUPS (10 min)

El actor no fue solo por la estación del usuario. Filtra:

```
rule.groups: locked3d and data.win.system.computer: SRV-DB-01
```

Fíjate en el evento de cifrado sobre `D:\backups\db\...`: **el atacante cifró una copia de backup en el servidor de base de datos**. Ese es el hilo que sigues en la Parte 2 (hunting) para responder: **¿qué backup quedó corrupto y cuál sirve para restaurar?**

Anota los **IOCs** que ves (los usarás en el informe): el proceso `l3d_core.exe`, la extensión `.locked3d`, la nota `LEEME_RESCATE.txt`, el dominio `descifra-express.onion`, el usuario y los hosts.

✅ **Checkpoint Parte 1:** tienes la kill chain reconstruida con sus técnicas MITRE, identificaste paciente cero (FIN-PC-07) y el objetivo (SRV-DB-01 con un backup cifrado), y una lista de IOCs. Sigue la Parte 2: **hunting** en el endpoint para confirmar qué backup está corrupto.

Parte 2 · Hunting DFIR con Velociraptor

Taller Sesión 5 · Ciber-Recuperación (92-EAN) · Duración: 25 min Herramienta: **Velociraptor** (local, en TU VM Ubuntu). Es DFIR real.

El SIEM (Parte 1) te dijo que el atacante cifró un backup en **SRV-DB-01**. Ahora bajas al endpoint y lo confirmas con evidencia: **¿qué backup quedó corrupto y cuál sirve para restaurar?** No adivinas: lo pruebas con hash, entropía y YARA.

0. Prepara y arranca Velociraptor

En tu VM, desde la carpeta del lab:

```
bash velociraptor-alumno/preparar-velociraptor.sh
```

El script descarga Velociraptor, **siembra los backups del caso** en **~/backups-lab/** y arranca la GUI. Abre <https://127.0.0.1:8889> (usuario **admin**, clave **password**; acepta el certificado autofirmado).

En **~/backups-lab/** tienes el “servidor de backups” a investigar: - **produccion_2026-08-18.bak** — copia de la noche anterior. - **produccion_2026-08-19.bak.locked3d** — copia de la noche del incidente. - **LEEME_RESCATE.txt** — apareció junto a los backups. - **reglas/locked3d.yar** — la regla YARA de la Sesión 3.

1. Inventaría y hashea los backups (10 min)

En la GUI, ve a tu cliente (localhost) → **Collect Artifact** → **Generic.Collectors.File**. Como *glob* usa:

```
/home/*/backups-lab/**
```

Marca el cálculo de **hash (SHA-256)**. Al terminar, revisa los resultados: - ¿Qué archivos hay? ¿Cuál tiene una extensión sospechosa? - Anota el **SHA-256** de cada backup (lo pones en el informe como evidencia).

2. Distingue el backup corrupto del limpio (10 min)

Dos señales objetivas de que un archivo está **cifrado** (no solo “raro”):

(a) Entropía. Un backup normal (texto/SQL) tiene entropía baja (~5); uno cifrado se acerca a **8.0** (máxima aleatoriedad). Es exactamente el análisis de la **Sesión 2**. Compruébalo (en una terminal, o con un artefacto de Velociraptor):

```
python3 - <<'PY'
import math,glob,os
from collections import Counter
for f in sorted(glob.glob(os.path.expanduser("~/backups-lab/*.bak*"))):
    b=open(f,'rb').read(); c=Counter(b); n=len(b)
    e=-sum((v/n)*math.log2(v/n) for v in c.values())
    print(f"{os.path.basename(f):<38} entropía={e:.2f} {'** CIFRADO **'
          if e>7.5 else 'limpio'}")
PY
```

(b) YARA. Confirma que es la **familia Locked3D** (no un archivo cualquiera). En la GUI usa **Generic.Detection.Yara.Glob** con la regla **~/backups-lab/reglas/locked3d.yar** y el glob **/home/*/backups-lab/****. El **.locked3d** debe **dar hit** (cabecera **L3D!** + mutex); el **.bak** limpio, no.

Conclusión que debes poder defender con evidencia: - **Corrupto:** **produccion_2026-08-19.bak.locked3d** (entropía ~8.0 + hit YARA Locked3D). - **Limpio y restaurable:** **produccion_2026-08-18.bak** (entropía baja, sin hit).

3. Recolecta el resto de la evidencia (5 min)

Para el informe, recolecta también: - La **nota de rescate** (**LEEME_RESCATE.txt**) — contenido y hash. - El **momento** en que apareció el **.locked3d** (timestamp del archivo) — cruza con la línea de tiempo del SIEM (Parte 1). - Opcional: **Generic.Collectors.File** sobre **/tmp** o **%TEMP%** buscando el **l3d_core.exe** de la kill chain.

✅ **Checkpoint Parte 2:** identificaste con **evidencia** (hash + entropía + YARA) cuál backup está corrupto y cuál sirve para restaurar, y confirmaste que es la familia Locked3D. Sigue la Parte 3: **monitorea tu bóveda** y **entrega el informe**.

Parte 3 · Monitorea tu bóveda y entrega el informe

Taller Sesión 5 · Ciber-Recuperación (92-EAN) · Duración: 25 min Herramientas: **MinIO** (tu bóveda) + **Wazuh** (monitoreo), por navegador.

Ya sabes qué pasó (Parte 1) y cuál backup está corrupto (Parte 2). Ahora cierras el ciclo del blue team: **custodiar el backup** — que exista una copia intocable y que el SIEM **avise** si alguien la ataca. Y entregas el informe.

1. Deposita un backup en tu bóveda (5 min)

Entra a la **consola de MinIO** con tu usuario (del CSV que te dio el docente):

```
https://<IP-del-SOC>:9001      usuario: alumnoNN      clave: EanSOC2026-xxxx
```

Verás **solo tu bucket** (**alumnoNN**) — es tu bóveda con Object Lock (WORM). Sube un archivo cualquiera como “backup” (botón **Upload**). Fíjate: hereda una **retención de 30 días** — no se puede borrar antes.

2. Simula el ataque y compruébalo en el SIEM (10 min)

Ponte en los zapatos del ransomware: **intenta borrar tu backup** desde la consola (selecciónalo → Delete). Observa dos cosas:

- **La bóveda resiste:** con Object Lock, el objeto no desaparece de verdad (queda protegido por WORM). Actívalo con “*Show deleted objects*” y verás que la versión sigue ahí. Igual que la Sesión 4.
- **El SIEM te avisa:** vuelve a Wazuh y filtra:

```
rule.id: 100231 and data.api.bucket: alumnoNN
```

Ahí está tu intento de borrado registrado (nivel 12, MITRE **T1490**), con tu **data.accessKey**. **Eso es monitorear un backup**: no basta con que sea immutable; el equipo azul tiene que *enterarse* de que alguien lo atacó.

Pregunta para el informe: ¿por qué la **combinación** importa? (inmutabilidad SIN monitoreo = no sabes que te atacan; monitoreo SIN inmutabilidad = ves el ataque pero pierdes el dato). Relaciónalo con la regla **3-2-1-1-0** de la Sesión 4.

3. Escribe el informe (10 min)

Usa la plantilla [PLANTILLA-informe-incidente.md](#). Debe quedar registrado, estilo forense:

- **Resumen ejecutivo** (3–5 líneas para dirección).
- **Línea de tiempo** del incidente (de la Parte 1, con horas y técnicas MITRE).
- **Hipótesis** que manejaste y cuál confirmaste con evidencia.
- **Hallazgos técnicos**: kill chain, IOCs, y **qué backup está corrupto vs cuál restaurar** (con hash + entropía + hit YARA de la Parte 2).
- **Técnicas MITRE ATT&CK** mapeadas (T1204.002, T1059.001, T1490, T1070.001, T1486, T1071).
- **Recomendaciones de recuperación y de monitoreo** de backups.

4. Entrega

Dos opciones (tu docente indica cuál):

- **Subir al repositorio** en la carpeta [informes/](#), con el nombre **nombre-y-dependencia.md** (o **.pdf**). Ejemplo: [juan-perez-contabilidad.md](#). Un informe por persona.
- **Entregar directo al docente** (si no usan el repo).

Lee [informes/README.md](#) para la convención exacta de nombre.

✅ **Checkpoint Parte 3 (fin del lab)**: monitoreaste tu propia bóveda (viste el ataque rebotar por WORM y aparecer como alerta en el SIEM) y entregaste un informe forense con la kill chain, el backup corrupto identificado y las técnicas MITRE. Cerraste el ciclo: **detectar** → **investigar** → **custodiar** → **recuperar**.